

User/OAuth Service

Shakti Singh | Structure & dependencies | proposed implementation guide

Purpose and ownership

Owns users, roles, OAuth2/OIDC, JWT/JWKS, profile, security audit and PostgreSQL. Notes, Blog and Billing validate tokens; Premium entitlement stays with Billing.

Dependencies

Java 21; Maven Wrapper; pinned Spring Boot/Security/Authorization Server; Web; OAuth2 Resource Server; JPA + JDBC; PostgreSQL; Flyway; Validation; Actuator; JUnit + Testcontainers.

Proposed package / class map

PACKAGE	CLASSES AND RESPONSIBILITY
config / security	AuthorizationServerConfig, SecurityFilterChainConfig, CorsConfig - protocol, API and browser chains
oauth	RegisteredClientConfiguration, JwtTokenCustomizer, JwkSourceConfiguration - PKCE client, claims, persistent keys
user/entity + repository	UserEntity, RoleEntity, UserRoleEntity, UserRepository, RoleRepository - private identity store
user/service + controller	RegistrationService, CurrentUserService, RegistrationController, CurrentUserController
user/dto	RegisterUserRequest, PatchMeRequest, UserResponse - caller-editable input, safe output
admin / recovery / audit	UserAdministrationService, PasswordRecoveryService, EmailVerificationService, SecurityAuditService (M2)
common/error	ApiExceptionHandler, ApiErrorResponse - standard business errors

Service links

React :5173 -> issuer :9000 (code + PKCE) -> Gateway :8080 -> Notes/Blog; issuer -> PostgreSQL. JWT: iss, sub, aud=technotes-api, roles, scope, exp. Resource services enforce role + scope + ownership.

Build order

B0 Flyway + persistent signing key -> M1 users/roles and PKCE/JWKS/token claims -> profile APIs -> real-token Notes integration -> M2 admin/recovery.

Implementation note

Public signup grants READER only. Blog scopes are new contract. Token is not payment proof. Verify pinned versions and repository state before coding.